

NORTHSTAR FINANCIAL SERVICES

INFORMATION SECURITY & CLOUD ARCHITECTURE POLICY BASELINE V4.2

DOCUMENT ID	EFFECTIVE DATE	POLICY OWNER	CLASSIFICATION
POL-SEC-2025-04	Oct 01, 2025	CISO & InfoSec Committee	Internal Restricted

1. PURPOSE & OPERATIONAL SCOPE

This policy defines the compulsory technical controls, cryptographic standards, architectural safeguards, and third-party assurance requirements for all cloud platforms, SaaS systems, software components, and AI solutions evaluated for procurement by Northstar Financial Services (NFS). No system handling customer data, financial records, or internal credentials may be provisioned without verified InfoSec sign-off.

2. GEOGRAPHIC DATA SOVEREIGNTY & STORAGE CONTROLS

NFS is subject to financial regulations including FINRA, SEC Rule 17a-4, GDPR, and NYDFS 23 NYCRR 500. Strict data localization controls apply:

- Approved Geographic Regions:** All Highly Confidential data, Personally Identifiable Information (PII), and financial transcripts must be processed, stored, and backed up exclusively within physical data centers located in the **United States (US) or European Union (EU)**.
- Multi-Tenant Isolation:** Multi-tenant SaaS architectures must enforce logical or physical isolation. Shared database schemas without unique, tenant-isolated cryptographic keys are strictly prohibited.
- Data Sanitization & Destruction:** Vendors must support automated data retention policies and guarantee cryptographic erasure (NIST SP 800-88 R1 compliant) across all primary instances and secondary backups within 30 days of contract termination.

3. TECHNICAL SECURITY CONTROLS & CRYPTOGRAPHIC STANDARDS

Vendors must implement continuous encryption and modern identity federation across all system interfaces:

DOMAIN	MANDATORY NFS BASELINE STANDARD	VALIDATION REQUIREMENT
Data at Rest	AES-256 encryption across all databases, object storage, and disk volumes. Customer-Managed Keys (CMEK via AWS KMS / Azure Key Vault) required for Tier-1 systems.	KMS key policy inspection & architectural diagram review.
Data in Transit	TLS 1.3 enforced for all external endpoints and internal service-to-service microservices. TLS 1.0, 1.1, and 1.2 are deprecated and prohibited.	SSLLabs Grade A+ scan or automated perimeter check.
Authentication & SSO	Native Single Sign-On (SSO) integration via SAML 2.0 or OpenID Connect (OIDC) tied to NFS Microsoft Entra ID / Okta. MFA via FIDO2 / TOTP required for admins.	IdP federation test in staging environment.
Key Management	Vendor personnel must never have unencrypted access to customer secrets or customer-held decryption keys. Hardware Security Modules (HSM FIPS 140-3 Level 3) required.	SOC 2 CC6.1 / CC6.3 control audit mapping.

InfoSec Security Rule: Vendors processing Tier-1 NFS workloads must support bring-your-own-key (BYOK) or customer-managed key (CMEK) architectures, allowing NFS to unilaterally revoke cryptographic access to data within 60 seconds.

4. THIRD-PARTY AUDITS & VULNERABILITY MANAGEMENT SLAS

All third-party technology providers must demonstrate continuous independent security verification and commit to strict vulnerability remediation timelines:

ASSURANCE ELEMENT	NFS MINIMUM BASELINE STANDARD	REMEDATION & FREQUENCY SLA
SOC 2 Type II Report	Unredacted report covering Security, Availability, and Confidentiality. Audit window must cover 12 continuous months ending within 12 months.	Annual resubmission required within 30 days of report issuance.
Penetration Testing	Executive summary of third-party network & application penetration test conducted within the last 365 days by an accredited CREST/OSCP security firm.	Zero unresolved Critical or High vulnerabilities prior to production deployment.
Vulnerability Patching (Critical)	CVSS 9.0–10.0 vulnerabilities in vendor code, OS, or third-party dependencies.	Patch deployment within 24 hours of discovery or CVE publication.
Vulnerability Patching (High)	CVSS 7.0–8.9 vulnerabilities in vendor software stack.	Patch deployment within 7 calendar days of discovery.

5. SECURITY RED-LINES & MANDATORY VETO CRITERIA

The InfoSec Specialist Agent will immediately issue an unappealable Security Veto (*Reject Status*) during automated evaluation upon detecting any of the following non-negotiable policy violations:

VETO Missing SOC 2 / ISO 27001 Refusal or inability to provide an unredacted SOC 2 Type II report or ISO/IEC 27001 certification without approved compensating controls.	VETO Unapproved Data Processing Region Storing, routing, or processing NFS customer data or telemetry outside US/EU borders without written waiver from the CISO.
VETO AI Training on Customer Data Vendor retention or utilization of NFS inputs, prompts, outputs, or telemetry for baseline model training or public optimization.	VETO Embedded Plaintext Secrets Storing production API keys, database passwords, or cryptographic certificates in source code repositories or unencrypted configs.

6. INCIDENT NOTIFICATION & BREACH PROTOCOL

In the event of a confirmed or suspected security incident, data breach, or unauthorized access impacting NFS systems or data:

- Notification Window:** Vendor must notify the NFS Security Operations Center (SOC) at soc@northstarfin.com within **15 minutes** of initial confirmation for P1 incidents.
- Forensic Reporting:** A complete Root Cause Analysis (RCA) and forensic timeline must be delivered to NFS InfoSec within **72 hours** of incident containment.